



NHÓM 2

**BIOMETRIC
AUTHENTICATION**

THÀNH VIÊN

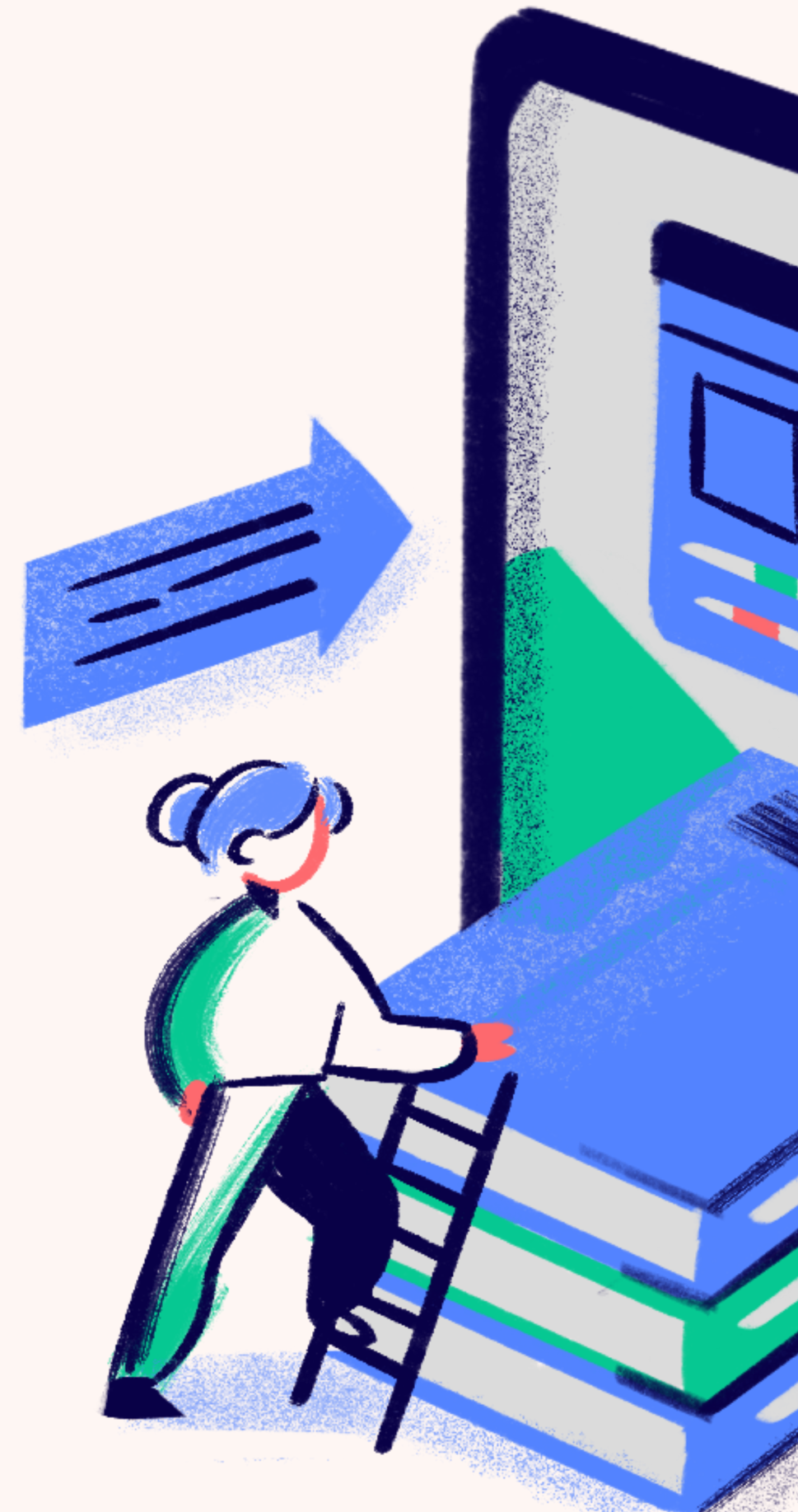
23120244 – Nguyễn Nhật Duy

23120252 – Nguyễn Phúc Hậu

23120255 – Lê Tấn Hiệp

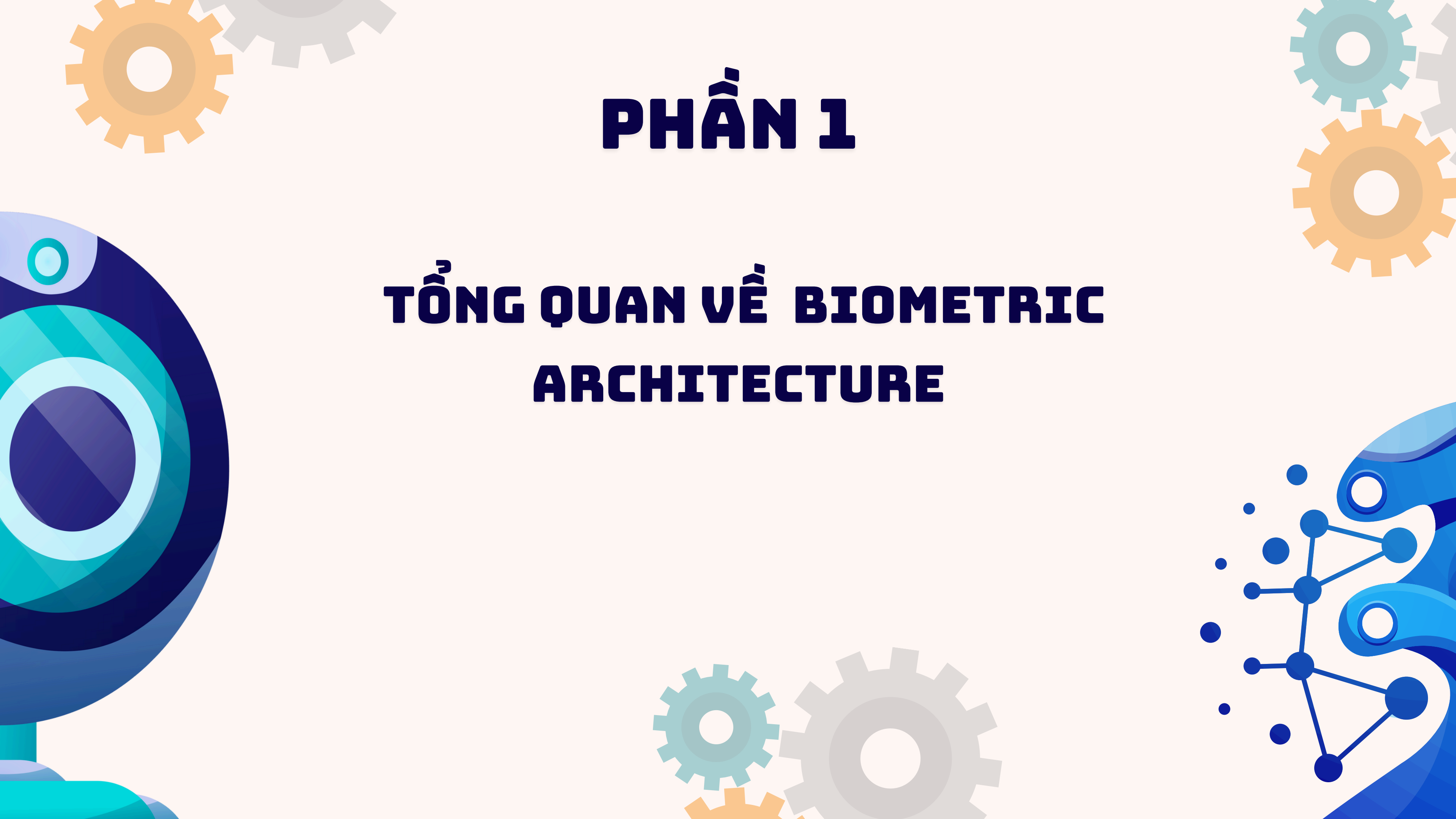
23120262 – Tống Dương Thái Hòa

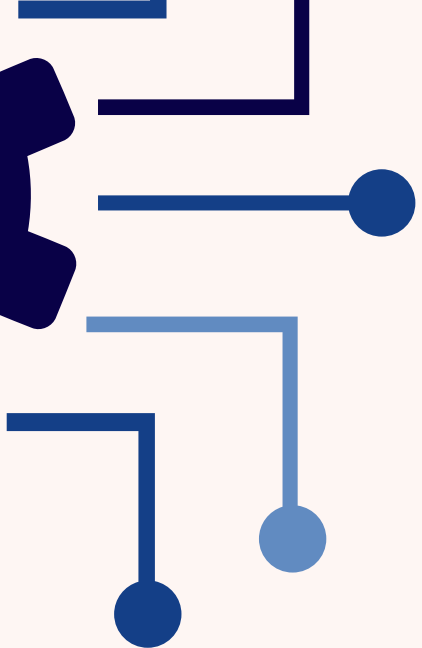
23120314 – Phạm An Ninh



PHẦN 1

TỔNG QUAN VỀ BIOMETRIC ARCHITECTURE





ĐỊNH NGHĨA



- Xác thực sinh trắc học là phương pháp xác thực người dùng dựa trên đặc điểm sinh học hoặc hành vi độc nhất của mỗi cá nhân
- Thay vì “biết cái gì” (password) hay “có cái gì” (thẻ, token), sinh trắc học xác thực dựa trên: “Bạn là ai”

Biometric Authentication xác thực dựa trên đặc điểm cơ thể (Vân tay, khuôn mặt...) để trả lời câu hỏi "Bạn là ai?".

CÁC LOẠI SINH TRẮC HỌC PHỔ BIẾN

◆ A. Đặc điểm sinh lý (Phổ biến nhất trên Mobile)

- **Vân tay (Fingerprint):** phổ biến nhất, chính xác cao, chi phí thấp
- **Nhận diện khuôn mặt (Face Recognition):**
 - 2D: dựa trên hình ảnh (kém an toàn)
 - 3D: dựa vào chiều sâu/hồng ngoại (FaceID, an toàn hơn)
- **Mống mắt (Iris):** bảo mật cực cao nhưng chi phí đắt đỏ

Ngoài ra còn có 1 số đặc điểm khác: võng mạc, hình dạng bàn tay...

CÁC LOẠI SINH TRẮC HỌC PHỔ BIẾN

◆ B. Đặc điểm hành vi

- Giọng nói (Voice)
- Dáng đi (Gait)
- Nhịp gõ phím (Typing rhythm)

Do đó, ít dùng trên Android cho xác thực hệ thống, thường dùng cho phân tích gian lận.

ĐẶC ĐIỂM, THUỘC TÍNH CỦA SINH TRẮC HỌC

Một hệ thống sinh trắc học tốt cần thỏa mãn:

- **Tính phổ biến:** Hầu hết ai cũng có
- **Tính duy nhất:** Không có ai giống nhau
- **Tính ổn định:** Không hoặc rất ít thay đổi
- **Khả năng thu thập:** Dễ dàng thu thập bằng thiết bị
- **Hiệu năng:** Tốc độ xử lý và chính xác cao
- **Khả năng chống giả mạo:** Khó có thể làm giả

CÁC MỨC ĐỘ XÁC THỰC BẰNG SINH TRẮC HỌC

A. Class 1 (BIOMETRIC_CONVENIENCE)

◆ Đặc điểm

- Mức bảo mật thấp
- Chủ yếu phục vụ trải nghiệm người dùng
- Chỉ được sử dụng ở mức hệ thống
- Ứng dụng bên thứ ba không thể truy cập API để dùng loại này

◆ Ví dụ: Face Unlock 2D trên các thiết bị giá rẻ

CÁC MỨC ĐỘ XÁC THỰC BẰNG SINH TRẮC HỌC

B. Class 2 (BIOMETRIC_WEAK)

◆ Đặc điểm

- Mức bảo mật trung bình
- Ưu tiên tiện lợi hơn là an toàn tuyệt đối
- Dùng để mở khóa thiết bị hoặc đăng nhập ứng dụng thông thường
- Không được dùng với Android Keystore / CryptoObject

◆ **Ví dụ:** Face Unlock camera thường, cảm biến sinh trắc chi phí thấp

CÁC MỨC ĐỘ XÁC THỰC BẰNG SINH TRẮC HỌC

C. Class 3 (BIOMETRIC_STRONG)

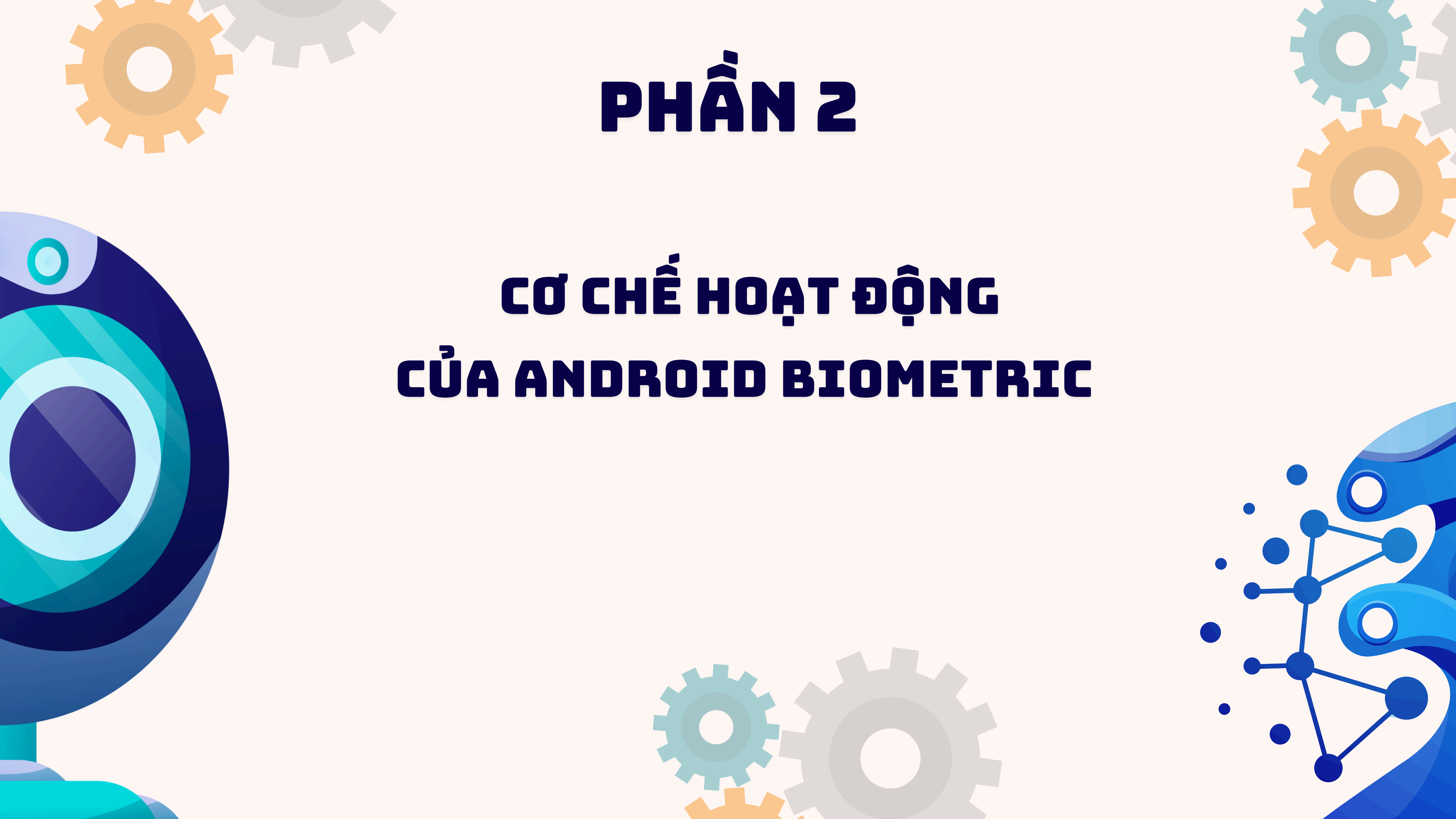
◆ Đặc điểm

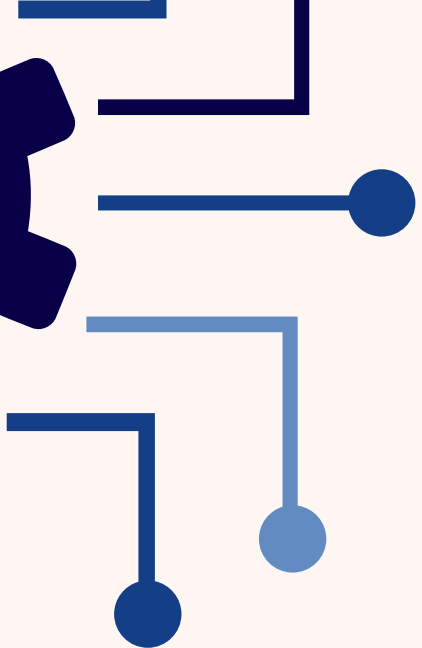
- Mức bảo mật cao nhất
- Độ chính xác cao, khả năng chống giả mạo tốt
- Được dùng với Android Keystore / CryptoObject
- Phù hợp với app nhạy cảm như tài chính, thanh toán

◆ **Ví dụ:** Vân tay siêu âm, Face Unlock 3D (cảm biến chiều sâu, hồng ngoại)

PHẦN 2

CƠ CHẾ HOẠT ĐỘNG CỦA ANDROID BIOMETRIC



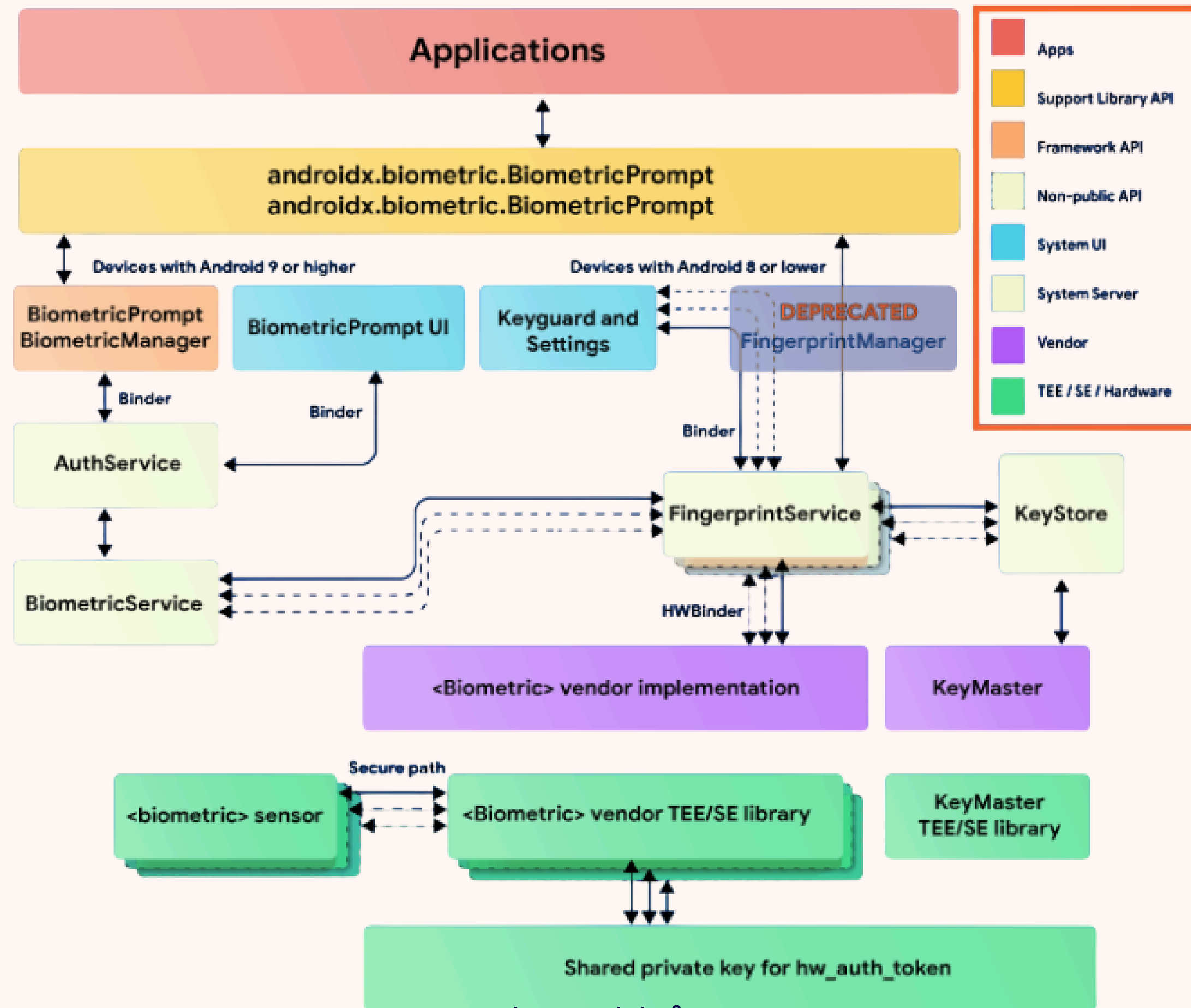


BIOMETRIC ARCHITECTURE

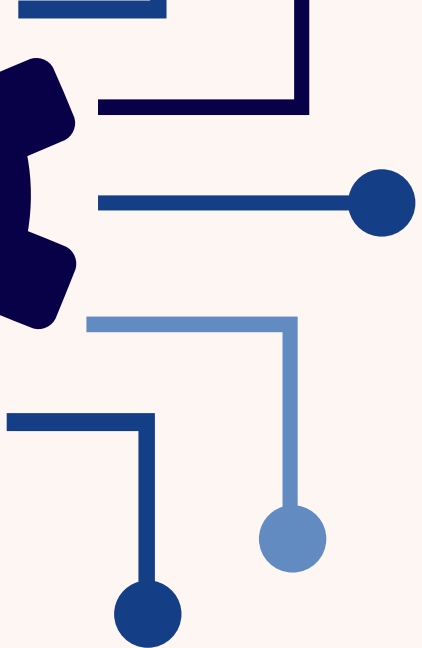


- Android chia thiết bị thành 3 cấp độ bảo mật: Class 3 (Strong), Class 2 (Weak), Class 1 (Convenience).
- Chỉ Class 3 và 2 mới được phép dùng BiometricPrompt.
- Dữ liệu sinh trắc được xử lý trong TEE (Trusted Execution Environment) → ứng dụng không được truy cập vào dữ liệu thật (chỉ nhận “OK/Fail”).

SƠ ĐỒ KIẾN TRÚC



Tham khảo



BIOMETRIC MANAGER



- Dùng để kiểm tra trước khi xác thực xem thiết bị có hỗ trợ không.
- Gọi: `BiometricManager.canAuthenticate(...)`
- Trả về: `BIOMETRIC_SUCCESS`, `ERROR_NO_HARDWARE`, `NONE_ENROLLED`, v.v.



BIOMETRIC MANAGER

```
val biometricManager = BiometricManager.from(this)
when (biometricManager.canAuthenticate(BIOMETRIC_STRONG or DEVICE_CREDENTIAL)) {
    BiometricManager.BIOMETRIC_SUCCESS ->
        Log.d("MY_APP_TAG", "App có thể xác thực sinh trắc sinh học.")
    BiometricManager.BIOMETRIC_ERROR_NO_HARDWARE ->
        Log.e("MY_APP_TAG", "Không có tính năng xác thực sinh trắc sinh học trên thiết bị này.")
    BiometricManager.BIOMETRIC_ERROR_HW_UNAVAILABLE ->
        Log.e("MY_APP_TAG", "Tính năng xác thực sinh trắc sinh học hiện không khả dụng.")
    BiometricManager.BIOMETRIC_ERROR_NONE_ENROLLED -> {
        // Hiện thị thông báo hướng dẫn người dùng tạo thông tin xác thực cho ứng dụng của bạn

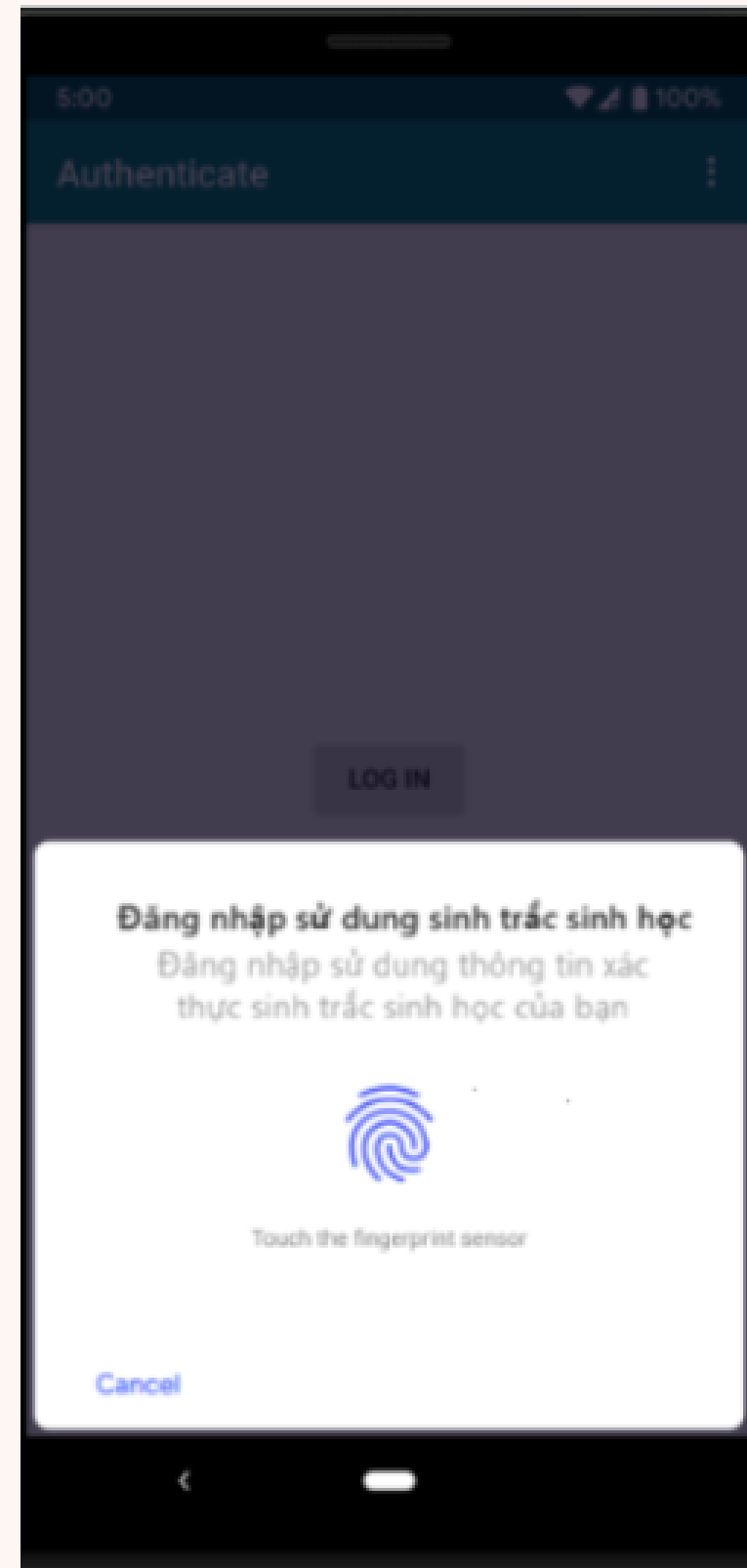
        val enrollIntent = Intent(Settings.ACTION_BIOMETRIC_ENROLL).apply {
            putExtra(Settings.EXTRA_BIOMETRIC_AUTHENTICATORS_ALLOWED,
                BIOMETRIC_STRONG or DEVICE_CREDENTIAL)
        }
        startActivityForResult(enrollIntent, REQUEST_CODE)
    }
}
```

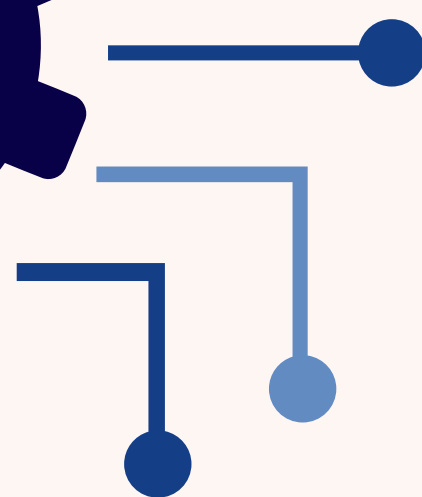



BIOMETRIC PROMPT

- API hiển thị hộp thoại sinh trắc (do hệ thống kiểm soát).
- Hộp thoại do System UI hiển thị.
- Hỗ trợ nhiều loại: vân tay, khuôn mặt, PIN.
- Giao diện người dùng thống nhất → an toàn.

ẢNH MINH HỌA



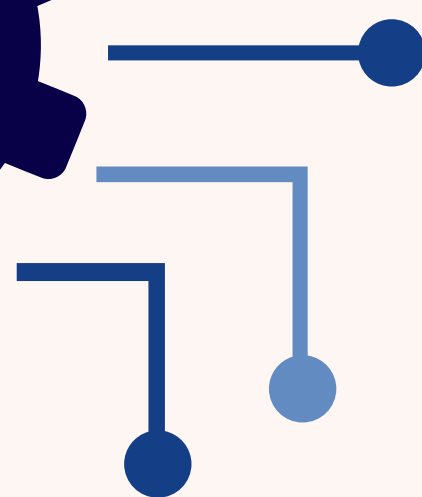


API PHỔ BIẾN NHẤT



- Hiện tại, BiometricPrompt (kết hợp với BiometricManager) chính là API tiêu chuẩn để triển khai xác thực sinh trắc trên Android.
- BiometricPrompt ra đời trên Android 9 (chỉ hỗ trợ vân tay lúc đầu) và được mở rộng trên Android 10 để hỗ trợ cả xác thực khuôn mặt, mang lại một giải pháp thống nhất cho mọi loại sinh trắc.





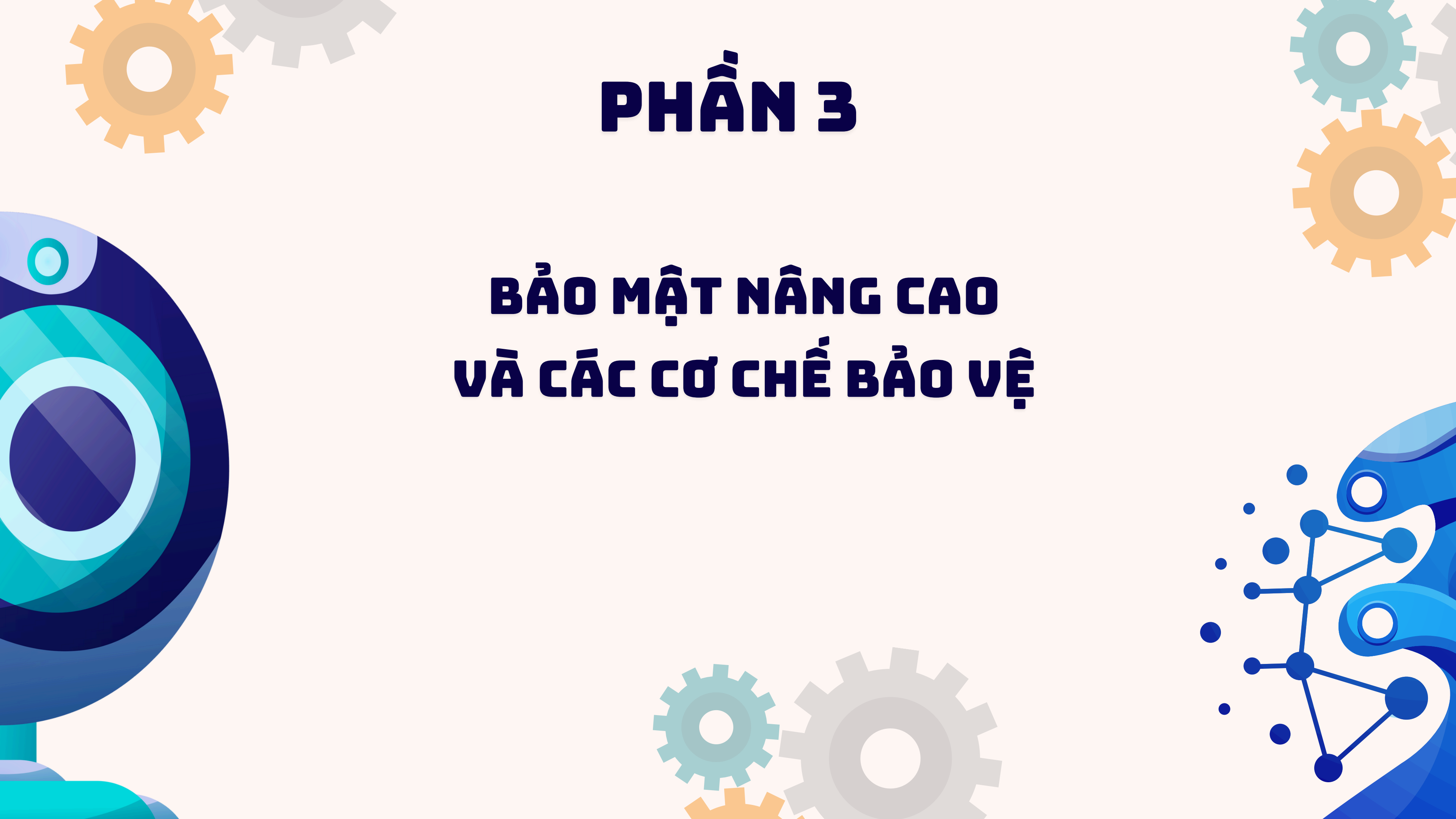
API PHỔ BIẾN NHẤT



- Nhờ tính tiện dụng và bảo mật, BiometricPrompt đã được nhiều ứng dụng thực tế áp dụng rộng rãi.
- Các ứng dụng ngân hàng, ví điện tử, trình quản lý mật khẩu... ngày nay đều tích hợp đăng nhập bằng vân tay hoặc khuôn mặt thông qua API BiometricPrompt, giúp người dùng đăng nhập nhanh chóng mà không cần ghi nhớ mật khẩu.
- Với BiometricPrompt, xác thực sinh trắc học trên Android đã trở thành một giải pháp “passwordless” phổ biến, nâng cao trải nghiệm người dùng trong khi vẫn đảm bảo an toàn cho dữ liệu.

PHẦN 3

BẢO MẬT NÂNG CAO VÀ CÁC CƠ CHẾ BẢO VỆ



BẢO MẬT NÂNG CAO VÀ TÍCH HỢP THỰC TẾ

BiometricPrompt của Android chỉ xác thực người dùng, không bảo vệ logic nghiệp vụ hay dữ liệu nhạy cảm. Kẻ tấn công thường nhắm vào mã nguồn và luồng xử lý ứng dụng.

Dịch ngược ứng dụng

Hacker dịch ngược APK để phân tích logic.

Can thiệp logic

Sử dụng công cụ để ép hệ thống gọi callback thành công, giả mạo xác thực.

Hậu quả

Ứng dụng nhận tín hiệu "xác thực thành công" giả mạo, dẫn đến truy cập trái phép.

Chỉ xác thực người dùng là chưa đủ. Cần ràng buộc xác thực với hành động mật mã không thể giả lập.

=> **Giải pháp:** sử dụng CryptoObject kết hợp Android Keystore.

CRYPTOOBJECT LÀ GÌ?

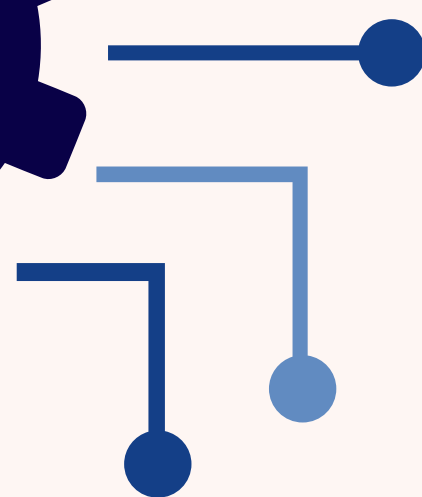
CryptoObject là đối tượng bảo mật trong Android, liên kết xác thực sinh trắc học với thao tác mật mã cụ thể. Nó đóng vai trò cầu nối giữa BiometricPrompt và các đối tượng mật mã (Cipher, Signature, Mac).

Xác thực sinh trắc học

Hệ điều hành Android chỉ cho phép CryptoObject kích hoạt thao tác mật mã khi người dùng xác thực sinh trắc học thành công.

Thao tác mật mã

Đảm bảo rằng hành động mã hóa/giải mã chỉ diễn ra sau khi xác thực hợp lệ.



Ý NGHĨA BẢO MẬT CỦA CRYPTOOBJEC



Ngăn chặn giả mạo

Chống lại việc giả mạo kết quả xác thực ở tầng ứng dụng.

Ràng buộc hành động

Đảm bảo xác thực sinh trắc học luôn gắn liền với hành động mật mã cụ thể.

Không thể bypass

Không thể vượt qua chỉ bằng cách sửa đổi mã nguồn hoặc can thiệp callback.

Kiểm soát hệ điều hành

Chuyển quyền kiểm soát bảo mật từ logic ứng dụng sang hệ điều hành.

ANDROID KEYSTORE LÀ GÌ?

Android Keystore là hệ thống bảo mật cấp hệ điều hành, cho phép ứng dụng tạo, lưu trữ và sử dụng các khóa mật mã trong môi trường an toàn.

Khóa không xuất ra ngoài

Khóa mật mã không thể xuất ra khỏi ứng dụng.

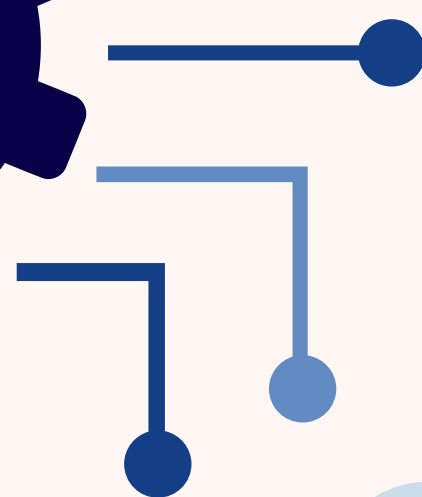
Không truy cập trực tiếp

Ứng dụng không truy cập trực tiếp giá trị của khóa.

Cấu hình linh hoạt

Khóa có thể cấu hình để yêu cầu xác thực sinh trắc học, hết hiệu lực sau thời gian, hoặc gắn với phần cứng bảo mật

Trong toàn bộ vòng đời, khóa mật mã không bao giờ truyền qua ứng dụng dưới dạng dữ liệu, mà chỉ được sử dụng gián tiếp qua các đối tượng mật mã do hệ điều hành kiểm soát.



KẾT HỢP BIOMETRIC + KEYSTORE: QUY TRÌNH CHUẨN

1

Khởi tạo khóa mật mã

Tạo khóa AES trong Android Keystore, cấu hình yêu cầu xác thực sinh trắc học.

2

Mã hóa dữ liệu nhạy cảm

Mật khẩu/token được mã hóa trước khi lưu trữ.

3

Yêu cầu truy cập

Ứng dụng tạo đối tượng Cipher để giải mã khi người dùng yêu cầu

4

Liên kết xác thực & mật mã

Cipher được đóng gói vào CryptoObject, truyền vào BiometricPrompt.

5

Xác thực sinh trắc học

Hệ điều hành hiển thị giao diện, người dùng xác thực

6

Giải mã dữ liệu

Chỉ khi xác thực thành công, Cipher mới kích hoạt, dữ liệu được giải mã và hiển thị.

TỔNG KẾT: BẢO MẬT TOÀN DIỆN

Xác thực sinh trắc học không thay thế mật khẩu, mà kiểm soát quyền sử dụng khóa mật mã. Việc kết hợp BiometricPrompt, CryptoObject và Android Keystore tạo cơ chế bảo mật toàn diện.

BiometricPrompt

Xác thực danh tính người dùng.

CryptoObject

Ràng buộc xác thực với hành động mật mã.

Android Keystore

Lưu trữ khóa mật mã an toàn.

Cơ chế này đảm bảo xác thực sinh trắc học được ràng buộc chặt chẽ với hành động mã hóa và giải mã dữ liệu nhạy cảm, mang lại sự an toàn cao cho ứng dụng.



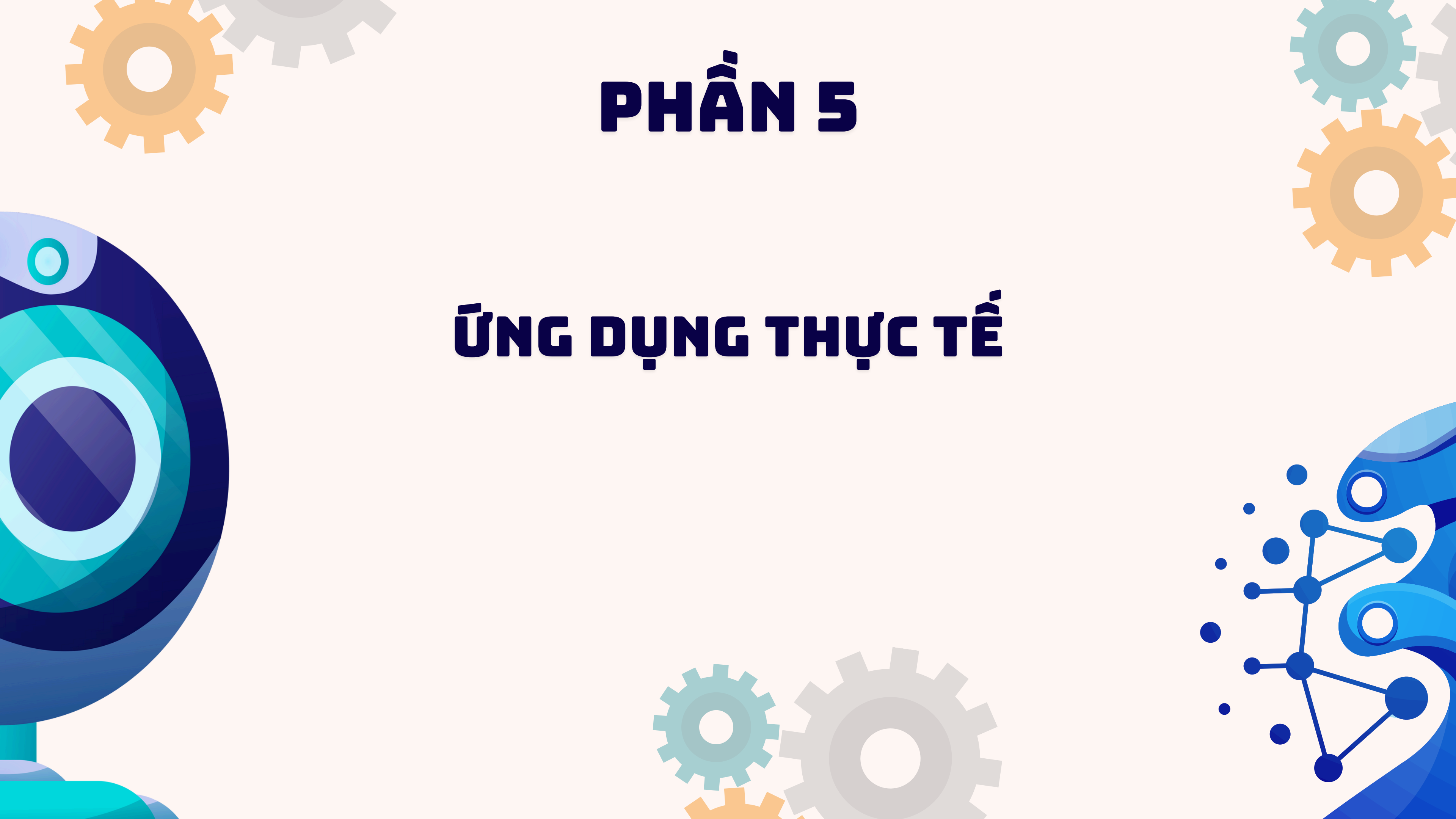
PHẦN 4

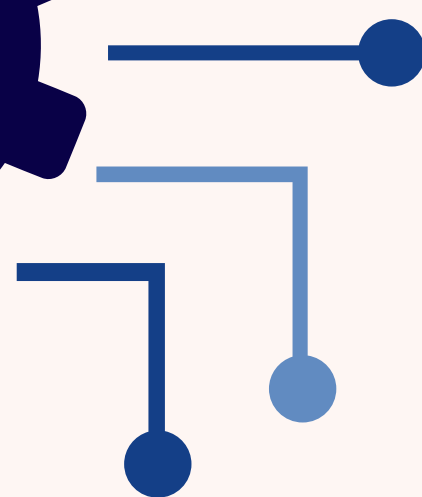
DEMO CODE KOTLIN



PHẦN 5

ỨNG DỤNG THỰC TẾ



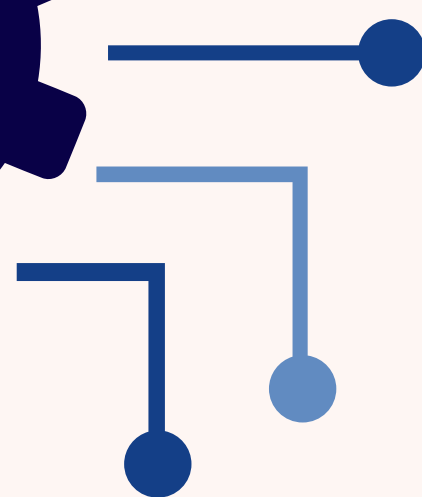


ỨNG DỤNG THỰC TẾ



- Mở khóa & bảo mật thiết bị
- Xác thực trong ứng dụng ngân hàng & ví điện tử
- Thay thế mật khẩu đăng nhập (Passwordless Login)
- Bảo vệ dữ liệu nhạy cảm trong app hay xác nhận một hành động quan trọng





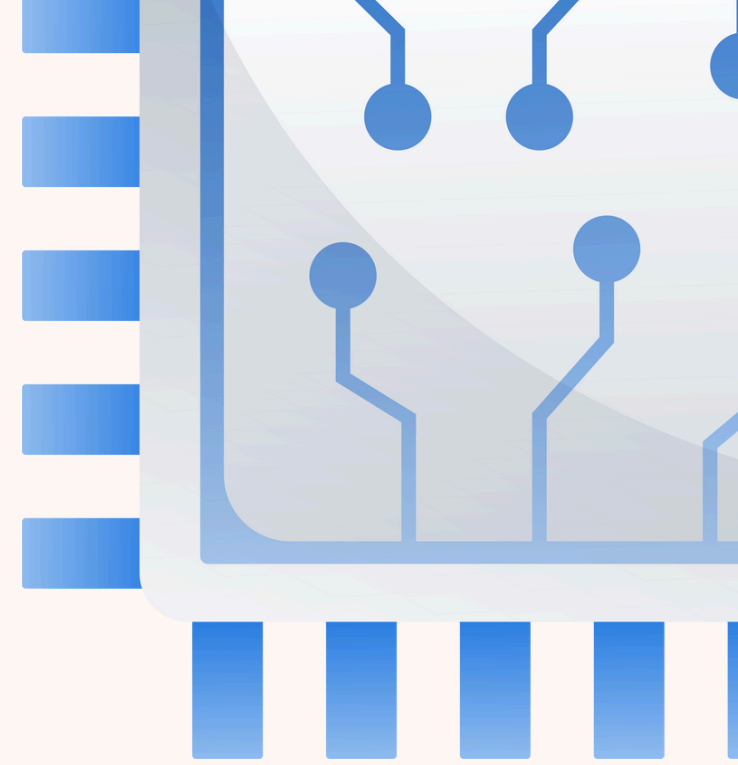
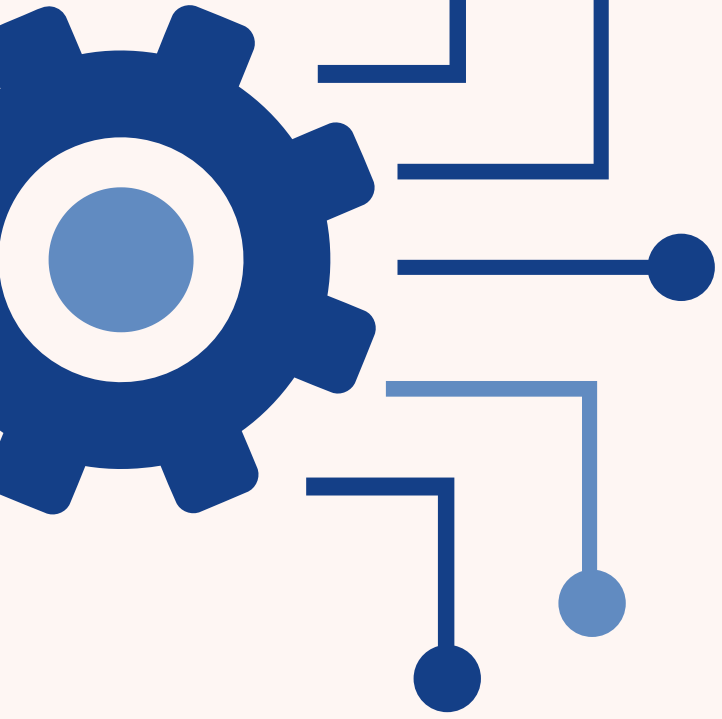
LỢI THẾ CỦA SINH TRẮC HỌC

- Không cần ghi nhớ → tránh lỗi con người
- Đăng nhập nhanh và tiện lợi hơn chỉ với 1 chạm
- Khó bị đánh cắp và giảm nguy cơ lộ mật khẩu
- Gắn với “đúng người”, không phải “đúng thông tin”



QUESTION TIME





**THANK
YOU**

